

Designing a DevSecOps Toolchain to Support ETL Workflows in Regulated Industries

Daniel Dickerson

October 14, 2025

Contents

1	Introduction	4
1.1	Context and Motivation	4
1.2	Problem Statement	4
1.3	Research Objectives	4
1.4	Contributions	5
1.5	Thesis Structure	5
2	Literature Review	6
2.1	Background	6
2.2	Defining Key Concepts	6
2.2.1	DevSecOps	6
2.2.2	ETL	7
2.2.3	Auditability	7
2.2.4	Governance	8
2.2.5	SDLC	8
2.2.6	Data Life Cycle	8
2.3	Research Questions	8
2.3.1	Main Research Question	8
2.3.2	Sub-questions	8
2.4	RQ1: ETL Pipelines in Regulated Industries	8
2.5	RQ2: DevSecOps and Governance in the SDLC	8
2.6	RQ3: Comparing the Data Lifecycle and the SDLC	8
2.7	RQ4: Tooling for Auditability and Governance	8
2.8	Synthesis	8
3	Methodology	9
3.1	Research Approach	9
3.2	Design Science Process	9
3.3	Case Study Context	9
3.4	Artifact Design Process	9
3.5	Evaluation Plan	9
3.6	Limitations	9
4	Baseline Pipeline	10
4.1	Overview	10
4.2	Architecture	10
4.3	Functionality	10
4.4	Observed Gaps	10
4.5	Summary	10
5	Proposed Architecture	11
5.1	Design Principles	11
5.2	High-Level Overview	11
5.3	Core Components	11
5.4	Integration with DevSecOps Practices	11
5.5	Expected Outcomes	11

6	Prototype Implementation	12
6.1	Implementation Environment	12
6.2	Toolchain Configuration	12
6.3	Security and Governance Layers	12
6.4	Demonstration	12
6.5	Challenges	12
7	Evaluation	13
7.1	Evaluation Framework	13
7.2	Experimental Setup	13
7.3	Results	13
7.4	Discussion	13
7.5	Threats to Validity	13
7.6	Summary	13
8	Discussion	14
8.1	Summary of Findings	14
8.2	Implications for Practice	14
8.3	Limitations	14
8.4	Future Work	14
9	Conclusion	15
9.1	Restating the Research Question	15
9.2	Key Contributions	15
9.3	Reflections	15
9.4	Closing Remarks	15

Chapter 1

Introduction

1.1 Context and Motivation

In recent years, the economic and operational value of data has surpassed that of the software systems which process it. Organisations are increasingly treating data as a product, complete with ownership structures, stewardship responsibilities, and lifecycle management requirements. This evolution has coincided with escalating regulatory scrutiny across jurisdictions. Frameworks such as APRA’s Prudential Standards [1–4] among international instruments such as the EU’s General Data Protection Regulation (GDPR) and the United States’ HIPAA mandate not only secure the handling of information assets, but also demand transparent processes that demonstrate accountability and control.

Extract–Transform–Load (ETL) workflows lie at the centre of this transformation. They serve as the operational backbone of analytical systems, ensuring that data is accurately extracted, transformed, and loaded into governed repositories. As Mahmud and Iqbal [5] emphasise, modern ETL pipelines have evolved into socio-technical infrastructures that sustain the scalability, reliability, and legitimacy of data-driven decision-making. Yet, despite the rise of DataOps practices, many data pipelines remain opaque, lacking end-to-end lineage, reproducibility, and verifiable controls. In regulated industries, this opacity undermines the ability to demonstrate compliance and erodes institutional trust.

The field of software engineering, by contrast, has already confronted similar challenges. DevSecOps—the integration of development, security, and operations—has matured into a discipline that embeds verification, automation, and governance throughout the software delivery lifecycle [6–8]. If data is now the product, then DevSecOps provides an architectural and cultural foundation for treating data pipelines with the same rigour historically applied to software systems. This research explores that proposition by examining how DevSecOps principles can be adapted to enable au-

ditability and *data governance* within ETL workflows.

1.2 Problem Statement

Although the DataOps movement has improved automation and observability within ETL processes, its focus has largely been operational efficiency rather than regulatory assurance [5, 9]. Current orchestration frameworks, while powerful, rarely produce immutable audit trails, reproducible execution states, or cryptographically verifiable lineage, leaving auditability an emergent rather than designed property [10, 11]. Consequently, organisations face a persistent gap between the technical execution of pipelines and the evidentiary requirements of regulators [1, 2].

This thesis addresses that gap. Specifically, it investigates how a *DevSecOps-enabled toolchain* can enhance auditability and data governance across the ETL lifecycle. Whereas DevSecOps has institutionalised security and compliance for software artifacts, an equivalent model for data artifacts has yet to emerge. The absence of such a model exposes regulated organisations to compliance risk, weakens governance, and impairs the ability to demonstrate trustworthy data management.

1.3 Research Objectives

This research adopts a Design Science methodology [12] to design, implement, and evaluate a DevSecOps-based toolchain that enhances auditability and data governance within ETL workflows. The study follows an iterative process of artifact design, prototype construction, and evaluation against explicit metrics for lineage completeness, reproducibility, and tamper detection.

The investigation is guided by the following research questions:

Main Research Question:

How can a DevSecOps toolchain be designed to support ETL workflows in regulated industries, enhancing auditability and data governance?

Sub-questions:

1. How do data workflows such as ETL manifest in regulated industries, and what auditability and data governance challenges do they face?
2. How do DevSecOps practices enhance auditability and data governance within the software development lifecycle?
3. In what ways do the stages of the data lifecycle align with or diverge from the stages of the software development lifecycle, and how does this affect the integration of DevSecOps practices?
4. What are the key categories of tooling in DevSecOps and in ETL pipelines, and how do their features compare in terms of supporting auditability and data governance?

- **Chapter 4** describes the baseline ETL pipeline and identifies auditability and data governance gaps.
- **Chapter 5** presents the proposed DevSecOps-integrated architecture.
- **Chapter 6** outlines the prototype implementation and tooling configuration.
- **Chapter 7** evaluates the system against auditability and data governance metrics.
- **Chapter 8** discusses the implications, limitations, and avenues for future research.
- **Chapter 9** concludes with reflections on how DevSecOps can enable trustworthy data governance in regulated environments.

1.4 Contributions

This thesis makes three primary contributions. First, it proposes an **architectural model** for a DevSecOps-enabled ETL toolchain, aligning the data lifecycle with secure software delivery practices to improve auditability and data governance. Second, it presents a **prototype implementation** that integrates infrastructure as code, automated security scanning, and immutable logging into an operational ETL environment based on Airflow, Spark, and AWS components. Third, it provides an **evaluation framework** that quantifies auditability and data governance using traceability, reproducibility, and tamper-resistance metrics. Together, these contributions establish a proof-of-concept for embedding DevSecOps principles within data-centric systems in regulated environments.

1.5 Thesis Structure

The remainder of this thesis is organised as follows:

- **Chapter 2** reviews the literature on ETL pipelines, data governance frameworks, and DevSecOps practices.
- **Chapter 3** details the Design Science methodology and research design.

Chapter 2

Literature Review

This chapter reviews the state of knowledge relevant to the design of ETL pipelines in regulated industries and the application of DevSecOps principles. It begins by introducing the context of ETL and governance requirements, then defines the key concepts used in this thesis. From this foundation, the research questions are posed explicitly. Each subsequent subsection addresses one sub-question through a focused review of the literature.

2.1 Background

- pipelines underpin data-intensive systems, producing usable data for fraud detection, market analysis, compliance reporting, and application metadata processing.

- Although the extract-transform-load process appears straightforward, in practice it is resource-intensive, complex, and often the most time-consuming part of data warehousing [13].

- ETL pipelines function as the “eyes of the system,” feeding downstream analytics and operations; failures or opacity here undermine the reliability of the entire enterprise stack.

- In regulated industries, compliance is tied as much to *how* data is processed as to the outcomes produced.

- Regulatory frameworks (e.g., GDPR, SOX, APRA) require secure and responsible handling of data, not just correct outputs.

- Auditability can be understood as the ability to demonstrate compliance through reproducibility, lineage, and tamper-resistant logs. [Find relevant citation here]

- Governance encompasses the policies, frameworks, and controls that institutionalize compliance practices. [Find relevant citation here]

- Failures in either area expose organizations to fines, license revocation, reputational damage, and loss of investor trust. [Find relevant citation here]

- DevOps was originally conceived to accelerate software delivery cycles through automation,

CI/CD, and rapid feedback loops. [Find relevant citation here]

- DevSecOps extends this model by embedding security and compliance throughout the software development lifecycle, using practices such as automated testing, compliance-as-code, artifact signing, and immutable logging [6, 7].

- These practices generate auditable artifacts that can be inspected by regulators and governance stakeholders, bridging engineering and compliance concerns.

- Data itself is increasingly recognized as a valuable artifact, often outweighing the systems that process it. [Find relevant citation here]

- This shift has intensified regulatory scrutiny of data workflows, highlighting the need to extend DevSecOps principles into ETL pipelines [14].

2.2 Defining Key Concepts

2.2.1 DevSecOps

DevSecOps can be understood as the proactive and continuous enforcement of security and compliance requirements throughout the software development lifecycle (SDLC) [6]. Opposed to approaches that treat security as a separate stage or external review, DevSecOps seeks to embed security within every stage of the lifecycle [8]. In this model, compliance is the default state, and deviations from established requirements are treated as explicit exceptions that must be justified [7].

A defining characteristic of DevSecOps is its reliance on automation to enforce non-functional requirements; such as auditability and governance. This is achieved through testing, provisioning, monitoring, logging, and policy enforcement [6, 15]. These automated controls produce auditable evidence, such as immutable logs and signed artifacts, that can be evaluated by regulators or auditors; effectively bridging the concerns of development teams and governance stakeholders [8].

Through the integration of cultural expectations and shared responsibility with technical mech-

anisms for enforcement, DevSecOps establishes a framework where security and compliance are continuous, measurable, and intrinsic to software delivery, rather than externally imposed constraints.

2.2.2 ETL

Extract-Transform-Load (ETL) is a structured pattern of processes, that ingests data, transforms it into analytics-ready formats, and persists it into target repositories such as data warehouses, data lakes, or file stores [13]. ETL is traditionally characterized by three interdependent stages: extraction, the sourcing of data from diverse and often inconsistent operational systems; transformation, the cleansing, standardization, integration, and reshaping of this data into consistent semantic structures; and loading, the deposition of transformed data into persistent storage for later use [13]. Kimball and Caserta emphasize that ETL has historically represented the most time-consuming and resource-intensive component of data warehousing, serving as the critical link between operational data and use.

While the classical framing describes ETL as a sequential and batch-oriented workflow, modern practice reflects more flexible execution models, including extract-load-transform (ELT) and hybrid streaming-batch architectures that exploit distributed and cloud-native infrastructure [5]. Beyond data movement, ETL operationalizes data integration, ensures quality and standardization, and increasingly serves as a locus for governance and compliance requirements. In regulated industries, ETL pipelines are expected not only to provide scalable data preparation, but also to guarantee lineage, reproducibility, and auditability as part of broader data governance frameworks [5].

Accordingly, ETL should not be conceived as a rigid boundary of operations, but as a flexible socio-technical pattern that concludes once data is made persistent and reusable, yet intersects with wider lifecycle concerns such as orchestration, monitoring, and policy enforcement. In this sense, ETL pipelines underpin both analytic scalability and the assurance of institutional trust and regulatory legitimacy [5].

2.2.3 Auditability

Auditability is a designed property of systems that enables their processes, controls, and outcomes to be observed and verified by stakeholders. Weigand and Elsas [11] define auditability through five interdependent requirements:

- **Normativity:** the presence of a clear regulatory or contractual framework governing

operations.

- **Accountability:** the production of verifiable statements linking actions to responsible agents and norms.
- **Referentiality Infrastructure:** the existence of records that connect operations to points of first recording.
- **Reliability:** the faithful and tamper-resistant representation of events;
- **Rerifiability:** the ability of external parties to test or validate the correctness of claims.

While these originate in the domain of financial reporting and organizational control, it provides a transferable structure for information systems more broadly.

Extending these principles into technical settings, Wang et al. [10] demonstrate how auditability can be operationalized for cloud storage through mechanisms such as third-party verification, cryptographic proofs of integrity, and support for dynamic data operations. Their work highlights that auditability is not merely an organisational concept, but one that can be concretely engineered into data management infrastructures.

In the context of ETL pipelines and DevSecOps practices, these requirements translate directly into regulated-industry concerns:

- **Normativity:** embedding compliance and data protection policies within workflow execution.
- **Accountability:** associating each transformation or deployment with authenticated agents or automated processes.
- **Referentiality Infrastructure:** full lineage tracking across extraction, transformation, and loading.
- **Reliability:** immutable logs, signed artifacts, and cryptographic hashing.
- **Verifiability:** reproducibility testing and the possibility of independent or delegated audits via CI/CD-integrated checks.

Taken together, these adapted requirements frame auditability in ETL pipelines as a designed capability: every data operation and system change can be traced, reproduced, and independently validated against regulatory expectations.

2.2.4 Governance

2.2.5 SDLC

2.2.6 Data Life Cycle

2.3 Research Questions

Drawing from the gaps identified in prior work, this paper will address the following:

2.3.1 Main Research Question

How can a DevSecOps toolchain be designed to support ETL workflows in regulated industries, enhancing auditability and governance?

2.3.2 Sub-questions

1. How does ETL manifest in regulated industries, and what auditability and governance challenges are faced?
2. How do DevSecOps practices enhance auditability and governance within the software development lifecycle?
3. In what ways do the stages of the data lifecycle align with or diverge from the stages of the software development lifecycle, and how does this affect the integration of DevSecOps practices?
4. What are the key categories of tooling in DevSecOps and in ETL pipelines, and how do their features compare in terms of supporting auditability and governance?

2.4 RQ1: ETL Pipelines in Regulated Industries

2.5 RQ2: DevSecOps and Governance in the SDLC

2.6 RQ3: Comparing the Data Lifecycle and the SDLC

2.7 RQ4: Tooling for Auditability and Governance

2.8 Synthesis

Chapter 3

Methodology

3.1 Research Approach

Explain the overall design science methodology used. Justify its selection for solving an engineering problem through artifact design.

3.2 Design Science Process

Describe each stage:

- **Problem identification:** Auditability and governance gaps in ETL.
- **Artifact design:** A DevSecOps toolchain architecture.
- **Demonstration:** Implementing the prototype.
- **Evaluation:** Measuring lineage, reproducibility, and tamper detection.

3.3 Case Study Context

Briefly describe the regulated domain (e.g., financial systems, SEC filings dataset). Justify its representativeness and constraints.

3.4 Artifact Design Process

Detail the iterative development process—tools, versioning, and validation loops.

3.5 Evaluation Plan

Summarize how you'll measure auditability, reproducibility, and tamper resistance.

3.6 Limitations

Acknowledge what is out of scope or constrained (e.g., scalability, dataset variety).

Chapter 4

Baseline Pipeline

4.1 Overview

Describe the initial ETL setup (Airflow + Spark + S3, deployed via Docker). Explain its purpose as a comparison point.

4.2 Architecture

Insert a diagram showing the baseline system structure. Highlight key components and data flow.

4.3 Functionality

Detail how data moves through extraction, transformation, and loading.

4.4 Observed Gaps

Discuss deficiencies in:

- Lineage tracking
- Reproducibility
- Governance and security controls

4.5 Summary

Conclude with why the baseline cannot meet auditability expectations.

Chapter 5

Proposed Architecture

5.1 Design Principles

Outline the guiding principles of the proposed DevSecOps-integrated ETL system: automation, immutability, traceability, reproducibility.

5.2 High-Level Overview

Provide an architectural diagram comparing baseline and proposed design.

5.3 Core Components

Explain each layer:

- **Infrastructure as Code:** Terraform for provisioning.
- **Orchestration:** Airflow for controlled execution.
- **Security:** CI/CD checks, artifact signing, SAST/SCA.
- **Governance:** Immutable audit logs, metadata tracking.

5.4 Integration with DevSecOps Practices

Map the proposed pipeline to the DevSecOps lifecycle (plan → code → build → test → release → monitor).

5.5 Expected Outcomes

Summarize the architectural advantages for auditability and compliance.

Chapter 6

Prototype Implementation

6.1 Implementation Environment

List the environment setup: AWS EMR, EC2, S3, Docker, GitHub Actions, Terraform.

6.2 Toolchain Configuration

Show how tools interconnect (e.g., Airflow triggers Spark, CI/CD automates IaC).

6.3 Security and Governance Layers

Describe:

- Hash signing of artifacts
- Immutable logging mechanisms
- Versioned configuration and audit history

6.4 Demonstration

Summarize execution flow with example runs and screenshots.

6.5 Challenges

Briefly discuss debugging, integration issues, and trade-offs during build.

Chapter 7

Evaluation

7.1 Evaluation Framework

Define how the artifact is assessed — e.g., lineage completeness, reproducibility, tamper detection.

7.2 Experimental Setup

Describe datasets, test environments, and CI/CD validation routines.

7.3 Results

Present tables, metrics, and visualizations of outcomes.

7.4 Discussion

Interpret results in context: - How did the toolchain improve governance? - What measurable gains were observed?

7.5 Threats to Validity

Discuss internal and external validity considerations.

7.6 Summary

Wrap up the findings and prepare for the discussion/conclusion chapters.

Chapter 8

Discussion

8.1 Summary of Findings

Recap the main evaluation results and architectural improvements.

8.2 Implications for Practice

Explain how this approach could generalize to other regulated environments.

8.3 Limitations

Note scalability, data type constraints, or untested regulatory frameworks.

8.4 Future Work

Propose enhancements—e.g., integrating ML pipelines, policy-as-code frameworks, or extended logging.

Chapter 9

Conclusion

9.1 Restating the Research Question

Reiterate the main question and summarize how your design addressed it.

9.2 Key Contributions

List concrete deliverables (architecture, prototype, metrics, evaluation).

9.3 Reflections

Discuss broader lessons about DevSecOps integration into data pipelines.

9.4 Closing Remarks

Tie back to the motivation and note the continuing relevance for regulated industries.

Bibliography

- [1] Australian Prudential Regulation Authority, “Prudential Standard CPS 234: Information Security,” Canberra, ACT, Jul. 2019. [Online]. Available: https://www.apra.gov.au/sites/default/files/cps_234_july_2019_for_public_release.pdf
- [2] —, “Prudential Standard CPS 230: Operational Risk Management,” Canberra, ACT, Jul. 2025. [Online]. Available: <https://www.apra.gov.au/sites/default/files/2025-07/Prudential%20Standard%20CPS%20230%20Operational%20Risk%20Management%20-%20clean.pdf>
- [3] —, “Prudential Standard CPS 510: Governance,” Canberra, ACT, Jul. 2023. [Online]. Available: https://www.apra.gov.au/sites/default/files/prudential_standard_cps_510_governance.pdf
- [4] —, “Prudential Practice Guide CPG 235: Managing Data Risk,” Australian Prudential Regulation Authority (APRA), Canberra, ACT, Prudential Practice Guide CPG 235, Sep. 2013. [Online]. Available: https://www.apra.gov.au/sites/default/files/Prudential-Practice-Guide-CPG-235-Managing-Data-Risk_1.pdf
- [5] D. Mahmud and M. Z. Ikbali, “THE ROLE OF ETL (EXTRACT-TRANSFORM-LOAD) PIPELINES IN SCALABLE BUSINESS INTELLIGENCE: A COMPARATIVE STUDY OF DATA INTEGRATION TOOLS,” *ASRC Procedia: Global Perspectives in Science and Scholarship*, vol. 2, no. 1, pp. 89–121, Apr. 2022. [Online]. Available: <https://global.asrcconference.com/index.php/asrc/article/view/29>
- [6] M. Anisetti, N. Bena, F. Berto, and G. Jeon, “A DevSecOps-based Assurance Process for Big Data Analytics,” in *2022 IEEE International Conference on Web Services (ICWS)*, Jul. 2022, pp. 1–10. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/9885738>
- [7] C. Castellanos, C. A. Varela, and D. Correal, “ACCORDANT: A domain specific-model and DevOps approach for big data analytics architectures,” *Journal of Systems and Software*, vol. 172, p. 110869, Feb. 2021. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0164121220302594>
- [8] M. Anisetti, C. A. Ardagna, E. Damiani, and F. Gaudenzi, “A Semi-Automatic and Trustworthy Scheme for Continuous Cloud Service Certification,” *IEEE Transactions on Services Computing*, vol. 13, no. 1, pp. 30–43, Jan. 2020. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/7831357/authors>
- [9] A. R. Munappy, D. I. Mattos, J. Bosch, H. H. Olsson, and A. Dakkak, “From Ad-Hoc Data Analytics to DataOps,” in *Proceedings of the International Conference on Software and System Processes*, ser. ICSSP ’20. New York, NY, USA: Association for Computing Machinery, 2020, pp. 165–174, event-place: Seoul, Republic of Korea. [Online]. Available: <https://doi.org/10.1145/3379177.3388909>
- [10] Q. Wang, C. Wang, K. Ren, W. Lou, and J. Li, “Enabling Public Auditability and Data Dynamics for Storage Security in Cloud Computing,” *IEEE Transactions on Parallel and Distributed Systems*, vol. 22, no. 5, pp. 847–859, May 2011. [Online]. Available: <https://ieeexplore.ieee.org/document/5611497>
- [11] H. Weigand and P. Elsas, “Auditability as a Design Problem,” in *2019 IEEE 21st Conference on Business Informatics (CBI)*, vol. 01, Jul. 2019, pp. 276–285, ISSN: 2378-1971. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/8808092>

- [12] A. Hevner, A. R. S. March, S. T. Park, J. Park, Ram, and Sudha, “Design Science in Information Systems Research,” *Management Information Systems Quarterly*, vol. 28, pp. 75–, Mar. 2004.
- [13] R. Kimball and J. Caserta, *The Data Warehouse ETL Toolkit: Practical Techniques for Extracting, Cleaning, Conforming, and Delivering Data*. Wiley, 2004, iSBN: 9780764567575. [Online]. Available: <https://www.oreilly.com/library/view/the-data-warehouse/9780764567575/>
- [14] “From Ad-Hoc Data Analytics to DataOps | Proceedings of the International Conference on Software and System Processes,” archive Location: world. [Online]. Available: <https://dl.acm.org/doi/10.1145/3379177.3388909>
- [15] Y. Zhou, Y. Yu, and B. Ding, “Towards MLOps: A Case Study of ML Pipeline Platform,” in *2020 International Conference on Artificial Intelligence and Computer Engineering (ICAICE)*, Oct. 2020, pp. 494–500. [Online]. Available: <https://ieeexplore.ieee.org/abstract/document/9361315>